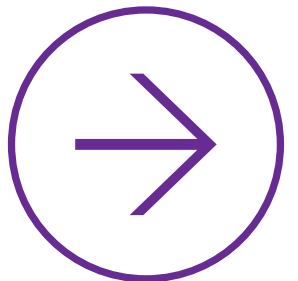


SecDevOps *Automation: an answer ?*



Your first call when it comes to IT Security!



SecDevOps

Impact of DevOps approach on the development cycle

- Implementation and delivery of business features become a continuous flow.
- Need to automate all steps that don't require human interaction.
- Refactor development, deployment and delivery process.
- Imply a move of the ways of thinks of all project members to an fully agile and collaborative mindsets.



SecDevOps

Impact of DevOps approach on the security

- Threats identification and abuse cases definition become continuous.
- Validation of the implemented/configured protections efficiency become continuous.
- Identification of flaws and related fixation become continuous.

So the security guys:

- Move from a advisory/validation posture at the begin/end of the product to a continuous validation of the security inside DevOps team.
- Must understand the Dev and the Ops daily jobs in order to provides technical supports on the 3 points above.
- Must help DevOps team to identify and automate all the security related checks that can be automated.

SecDevOps is just the add of new friend in the DevOps game, the Sec guy in order to bring a offensive/defensive mindset in the overall mindset...

SecDevOps

Which security checks can be automated?

- Static audit of the source code (often called **Static Application Security Testing**):
 - Focus on analyzing the source code, binary can sometime be created for introspection but application is not executed.
- Dynamic audit of the application (often called **Dynamic Application Security Testing**):
 - Focus on analyzing the application at runtime.
- 3rd party dependencies:
 - Focus on identify if dependencies used by the project contains public vulnerabilities.
- Web Application Firewall protection rules associated with an application:
 - Focus on implements functional tests in order to ensure that WAF rules are triggered if the expected event occurs.
- Dedicated security oriented unit/functional tests:
 - Focus on testing a component of the application from a security point of view (applied for sensitive or critical components).

SecDevOps

The dark side of security checks automation

- You will have to handle the following points that will come with automation:
 - Identification and handling of False-Positive issue raised and customization of the scan/audit tool.
 - Identification of False-Negative issue not raised and customization of the scan/audit tool.
 - Train Sec/Dev/Ops to analyze and understand/customize audit/scan reports.
 - Train Sec/Dev/Ops to derivate counter-measures to fix issues raised by the audit/scan tool.
 - Obtain the capacity to deploy any application on a sandbox operational environment in a fully automated way.
 - Search and identify adequate audit/scan tool according to your technologies context.
 - Train Sec/Dev/Ops on these tools and let them gain experience.
 - Define audit/scan initial profiles according to your technologies context.
 - Define the audit/scan profiles evolution roadmap in order to stick to the evolution skills of Sec/Dev/Ops in AppSec field (starting with hard profiles lead to demotivation and fail): Think smoothly !
 - Integrate the audit tool in the developer IDE in order to allow them to have a feedback about security issue during the implementation.
 - Define the policy of fixation if an issue is found on a 3rd party dependency.
 - Maintain and patch the scan/audit tool in order that do not become a attack surface.
 - Refactor the integration processes to include theses tools.

SecDevOps

The dark side of security checks automation

- You will have to handle the following points that will come with automation:
 - Identification and handling of False-Positive issue raised and customization of the scan/audit tool.
 - Identification of False-Negative issue not raised and customization of the scan/audit tool.
 - Train Sec/Dev/Ops to analyze and understand/customize audit/scan reports.
 - Train Sec/Dev/Ops to derivate counter-measures to fix issues raised by the audit/scan tool.

Whatever the dark side, automation of security checks is mandatory and helpful to create a quick feedback loop about common security issues meet during the implementation or maintenance.

- Define the policy of fixation if an issue is found on a 3rd party dependency.
- Maintain and patch the scan/audit tool in order that do not become a attack surface.
- Refactor the integration processes to include theses tools.

SecDevOps

The delta that become a combination

- They are some tasks and checks that cannot be automated:
 - Threats identification and abuse cases definition:
 - Analyze of the business features and exchanges with business analysts are required to allow the identification of misuse (abuse) cases of the features and the associated business impact to measure the importance to give to the case.
 - Fixation of the issues:
 - It's up to the human brain to decide where and how the issue must be fixed.
 - Advanced audit in order to spot complex issue like one related to the business logic:
 - Manual code review.
 - Manual intrusion test.
- It's important to remember that audit and scan automated tools, even with customization, are not yet able to find complex issues and will only found issues that follow a pattern. So, combination of manual and automated verification is highly recommended to enhance the audit coverage.

SecDevOps

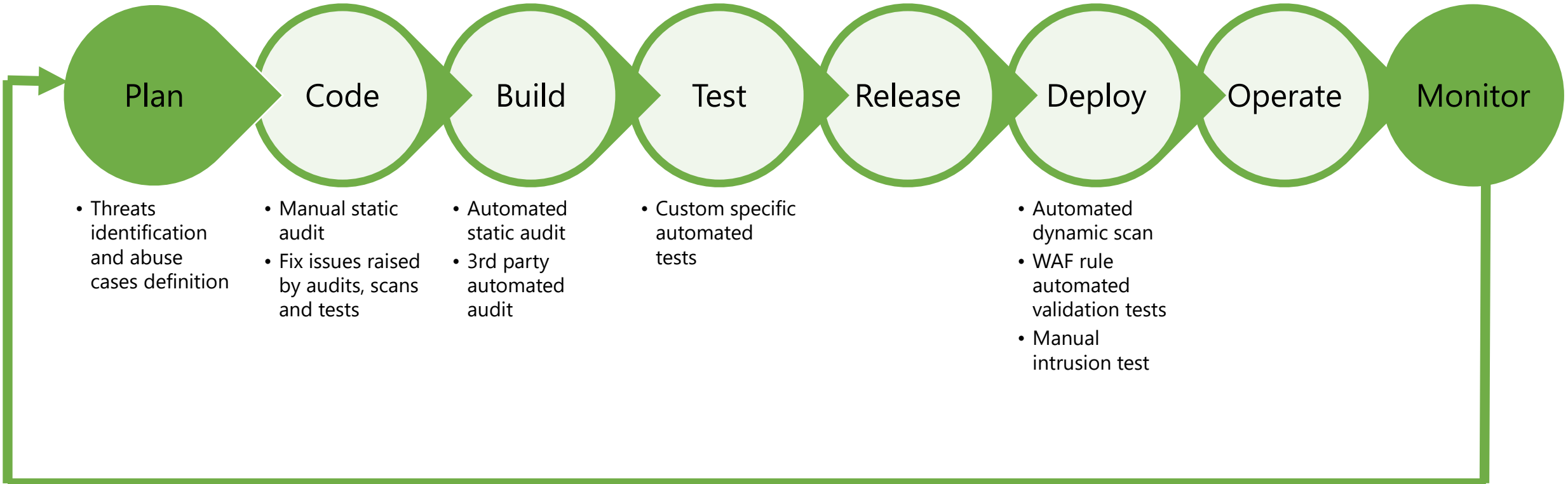
The cost and a progressive approach

- They are many checks and tasks (manual + automated) that can be performed in order to include the Security in DevOps but this inclusion have a cost in terms of time, money, change in organization hierarchy, change in job tasks...
- It's important grow in a progressive and empiric way by adding the different possible checks/tasks one by one after an evaluation period in order to let time to people and structure to learn, build XP and identify checks that are effective and ones that aren't and should be refactored.
- To resume, we have identified the following checks/task operations:
 - Threats identification and abuse cases definition.
 - Automated static audit.
 - Manual static audit.
 - 3rd party automated audit.
 - Automated dynamic scan.
 - Manual intrusion test.
 - WAF rule automated validation.
 - Custom specific automated tests.

SecDevOps

The cost and a progressive approach

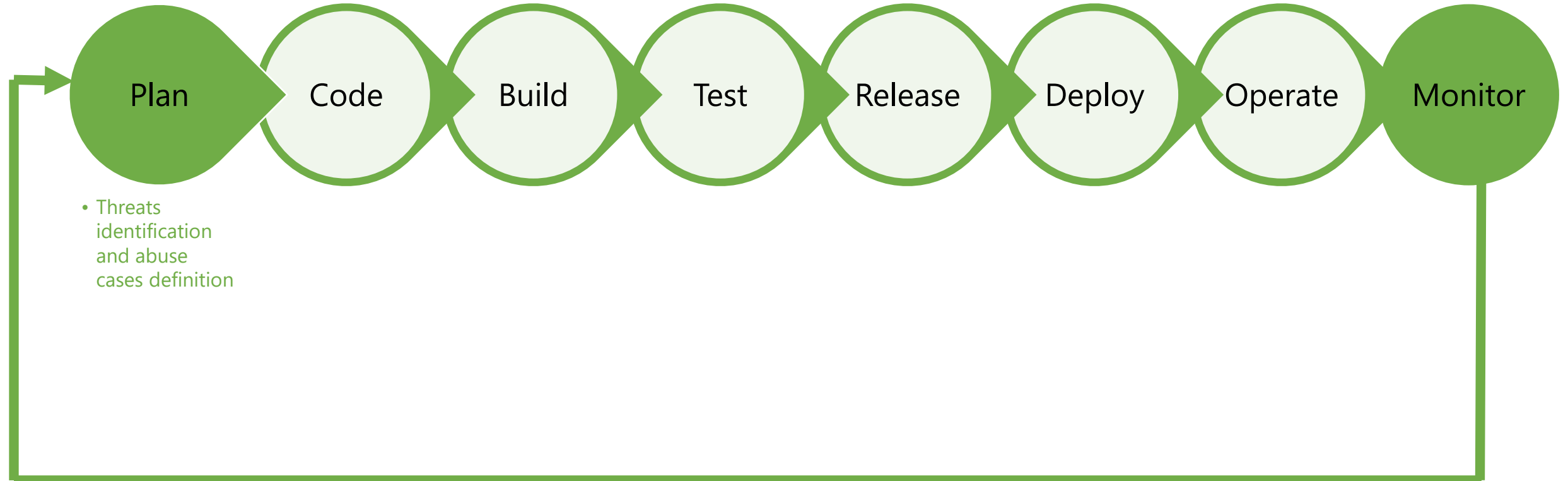
- Mapping of the security checks/tasks on the initial DevOps flow step in order to represent the target SecDevOps flow.
- We will use several phases to achieve this final flow:



SecDevOps

The cost and a progressive approach

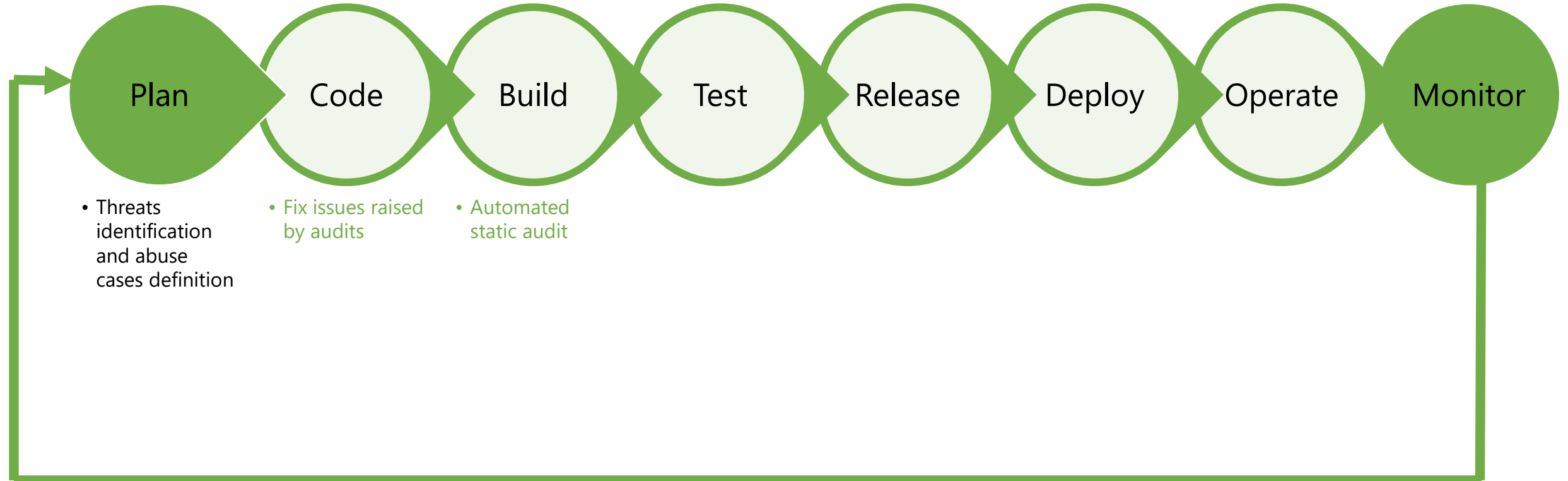
Phase n°0:



SecDevOps

The cost and a progressive approach

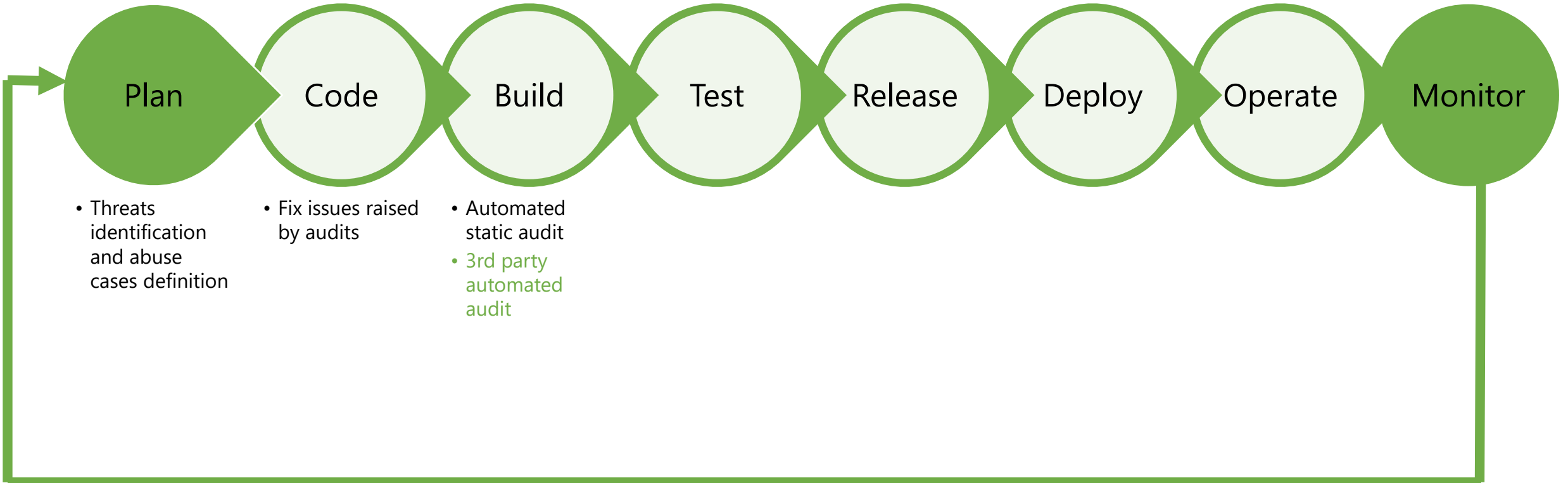
Phase n°1:



SecDevOps

The cost and a progressive approach

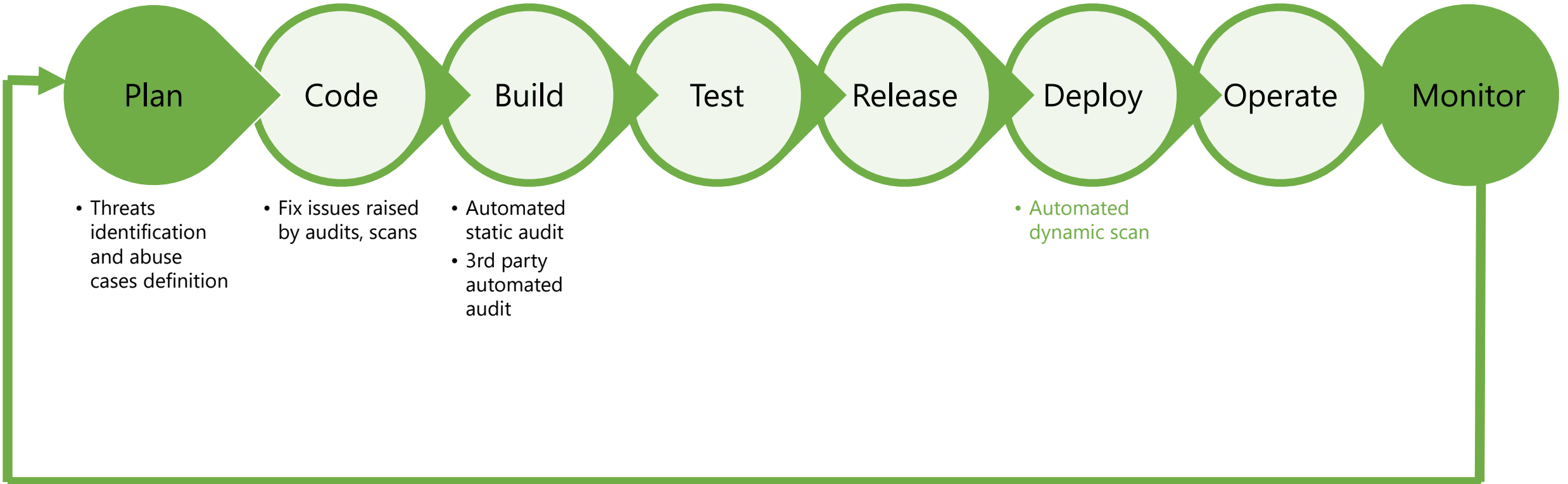
Phase n°2:



SecDevOps

The cost and a progressive approach

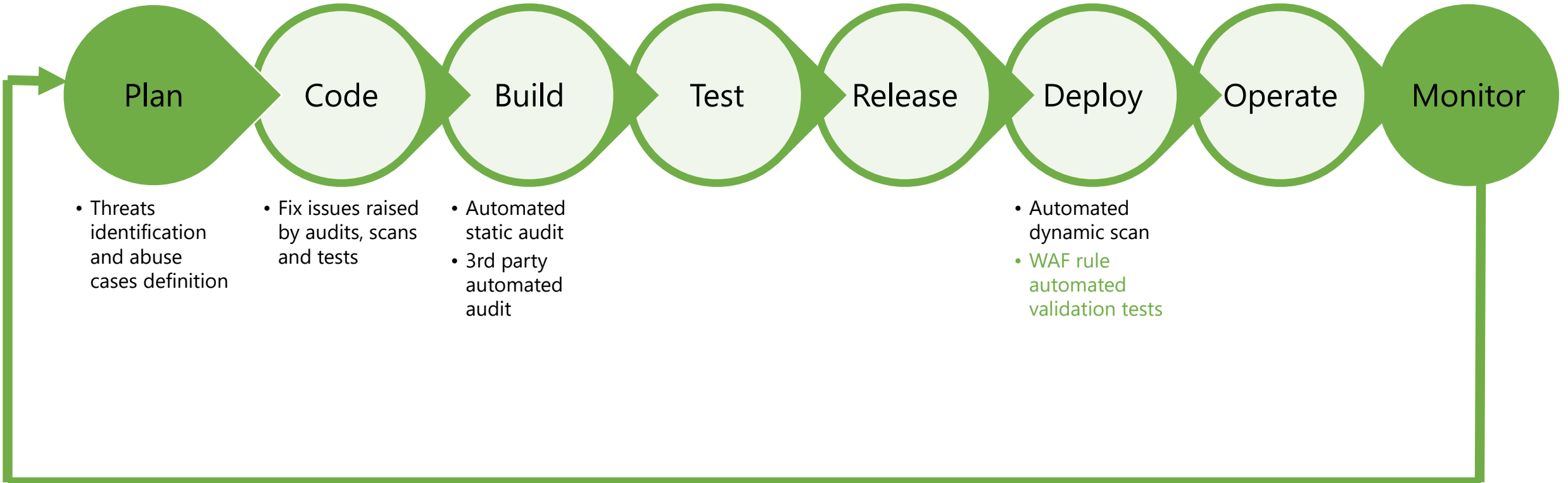
Phase n°3:



SecDevOps

The cost and a progressive approach

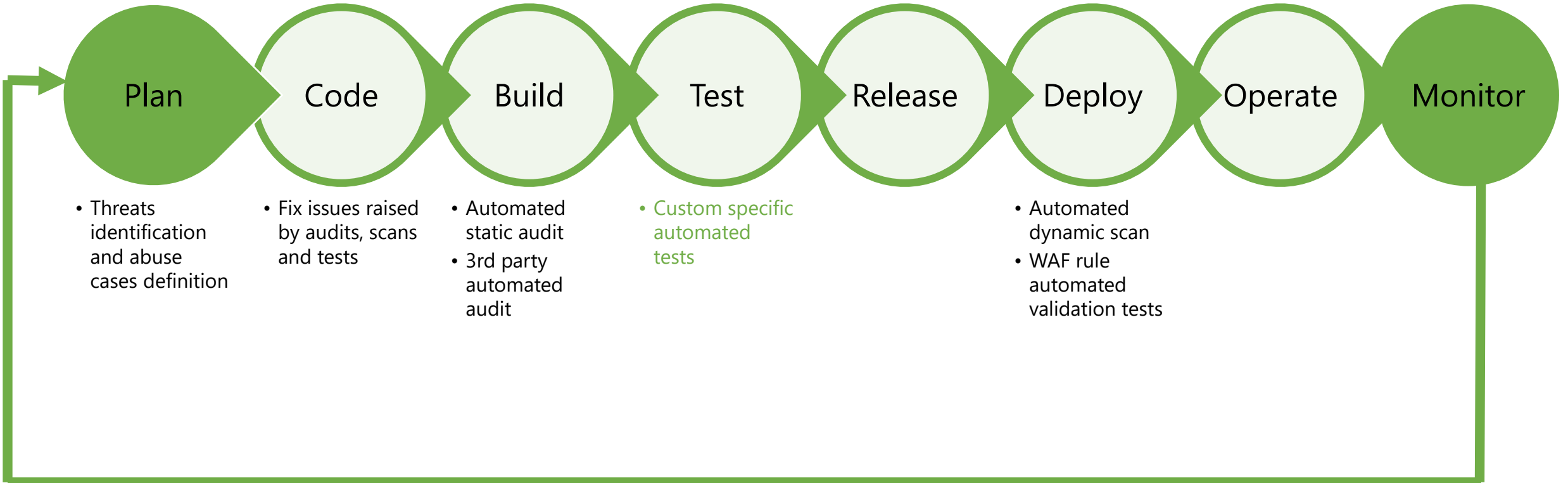
Phase n°4:



SecDevOps

The cost and a progressive approach

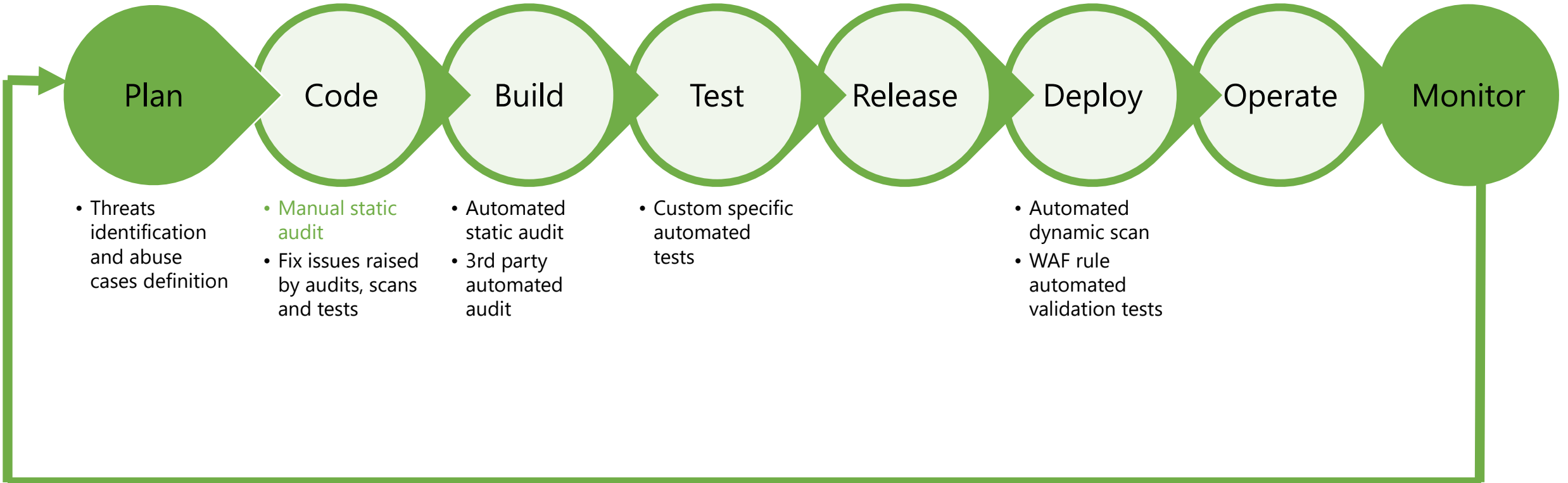
Phase n°5:



SecDevOps

The cost and a progressive approach

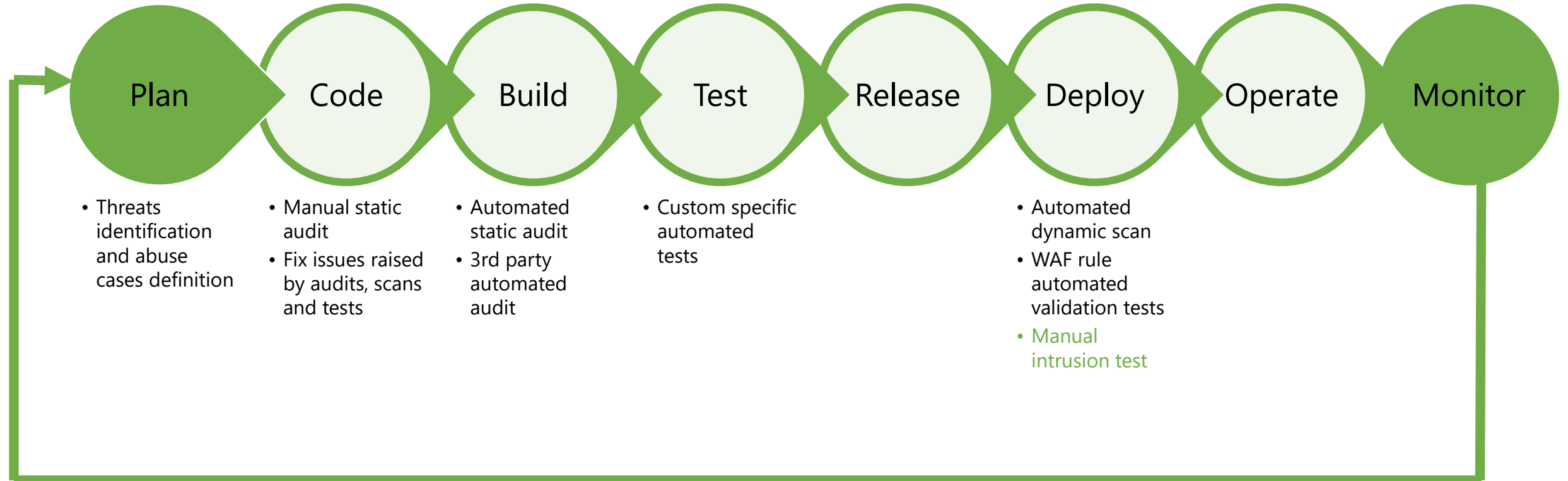
Phase n°6:



SecDevOps

The cost and a progressive approach

Phase n°7:



We have seen, through this presentation, that automation will help on some area but it must be combined with the work performed by human and processes.

So, it's important to remember that SecDevOps it's mainly a matter of human, collaboration, process, way of thinking and there no "SecDevOps ®" branded magic tool that can bring them to your organization...

Thank You

